

Security Architecture, Threat Modeling & Compliance Specification

Defense-in-Depth Implementation: Authentication, Cryptography, NoSQL Sanitization & DPDP Compliance

Academic and strategic research artifact for the AI-Powered Household Appliance Rental System (RentAI / SDC2). Demonstrating circular economy transition, machine learning churn mitigation, FunkSVD recommendation, and localized generative AI edge deployment.

Document Ref:	SEC-SDC2-2026-V2.4	Publication:	September 2026
Project Title:	RentAI / SDC2 Autonomous Rental Platform	Peer Review:	Academic Capstone & IEEE/ACM Format
Principal Authors:	Advanced AI & Systems Research Group	Affiliation:	Department of Computer Science & Engineering
Classification:	Scholarly Research & Field Engineering	Status:	PUBLISHED & ARCHIVED

1. Security Philosophy & Threat Model

RentAI implements a Defense-in-Depth security framework addressing the OWASP Top 10 API Security Risks. The architecture enforces zero-trust principles between decoupled tiers.

2. Authentication & Authorization Architecture

2.1 JSON Web Token (JWT) Security

Authentication utilizes **SimpleJWT** with HMAC-SHA256 signatures. Short-lived Access Tokens (validity: 60 minutes) are paired with Refresh Tokens (validity: 7 days) stored securely to minimize token replay vulnerability windows.

2.2 Cryptographic Password Storage

Passwords are never stored in plaintext. Passwords undergo cryptographic hashing via **PBKDF2 with a SHA256 digest** and 720,000 hashing rounds, incorporating unique cryptographically random 128-bit salts to protect against rainbow table attacks.

3. NoSQL Injection & Input Sanitization

Traditional SQL injection vulnerabilities are irrelevant due to the complete absence of relational SQL engines (``DATABASES = {}``). However, NoSQL operator injection (e.g. `{"$gt": ""}`) is prevented via strict MongoEngine ODM document typing, where non-primitive query keys are automatically rejected and sanitized before reaching the MongoDB storage engine.

4. Privacy & Regulatory Compliance (DPDP Act 2023)

Compliance Area	Technical Implementation	Status
User KYC Privacy	Stored in isolated MongoDB collection with restricted admin RBAC	COMPLIANT
Zero Data Leakage AI	Local Ollama LLM ensures queries never egress to public cloud APIs	COMPLIANT
Transport Encryption	TLS 1.3 / HTTPS enforcement on production gateways	COMPLIANT
CORS Whitelisting	Explicit origin domain whitelisting via `django-cors-headers`	COMPLIANT